

BOSTON UNIVERSITY
DEPARTMENT OF ELECTRICAL AND COMPUTER ENGINEERING

PhD Prospectus

**TOWARDS LAYERED DEFENSES FOR MOBILE FINANCIAL SAFETY:
PROTECTING USERS FROM PREDATORY APPS, CONSENT EROSION, AND
CONVERSATIONAL SCAMS**

By

OLAWALE AMOS AKANJI
B.Sc. Cyber Security, Air Force Institute of Technology, Nigeria, 2023
M.S., Boston University, 2026

Advisor: Prof. Gianluca Stringhini
Co-Advisor: Prof. Manuel Egele

Abstract

Mobile users face security and privacy threats at every layer of the ecosystem they depend on: the applications they install, the platform mechanisms that govern those applications, and the conversations they hold on their devices. This dissertation develops defenses for users at each of these layers. At the application layer, *The Cost of Convenience* (ACM ASIA CCS 2026) presents the first cross-country measurement of predatory loan-app compliance with national regulations and Google’s Financial Services Policy, analyzing 434 apps across five countries; following our disclosures, Google removed 93 apps representing over 300 million installs. Investigating how such apps retain access to sensitive data despite policy restrictions led to the platform layer: *Silent Consent, Persistent Risk* shows, through a longitudinal analysis of 19.3 million APKs, that Android’s permission groups silently auto-grant new permissions across updates (17% of multi-version apps expand silently, and malware does so at significantly higher rates) and that normal-level custom permissions expose sensitive data to unrelated apps without any prompt; a lightweight prototype restores update-time transparency without OS modification. Yet even compliant apps on a hardened platform cannot protect users who are manipulated directly. The proposed work, *SIRENBERT*, addresses the conversation layer: an on-device detector for pig-butcher scams that models a conversation’s behavioral trajectory message by message, achieving 0.99 SCAM-F1 and warning a median of eleven messages before the first money request. Completing *SIRENBERT*, its adversarial robustness, cross-platform coverage, and user-facing warnings, will establish protection at the layer closest to the user, completing a body of work that defends mobile users wherever exploitation reaches them.

1 Introduction

Mobile devices mediate nearly every aspect of their users’ lives, and for billions of people, particularly in emerging markets, they are the sole gateway to financial services [15, 7]. This centrality exposes users to security and privacy threats at multiple layers of the mobile ecosystem: the *applications* they install, the *platform mechanisms* that are supposed to govern what those applications can do, and the *conversations* they hold through their devices. My research protects users at each of these layers. Rather than one system, this dissertation comprises three studies, each identifying how users are harmed at one layer and delivering a concrete, deployed or deployable defense.

My work began at the application layer. In emerging markets, digital lending applications (loan apps) have become a primary channel for microcredit, but many demand excessive permissions and weaponize the harvested data, contact lists, SMS, photos, for coercive debt recovery: harassment, blackmail, and public shaming of borrowers and their contacts. In *The Cost of Convenience: Identifying, Analyzing, and Mitigating Predatory Loan Applications on Android* [1], we conducted the first cross-country measurement of loan-app compliance with national regulations and Google’s Financial Services Policy, and our disclosures led Google to remove 93 apps with over 300 million cumulative installs (§3).

That analysis raised a deeper question. While studying how loan-app developers retain access to sensitive data despite policy restrictions, we observed that circumvention does not always require malice or obfuscation: certain Android mechanisms enable it by default. Once a user approves one permission from a group, updates can silently add sibling permissions without any prompt, and developer-defined custom permissions at the default protection level are auto-granted at install with no user visibility at all. This moved my focus to the platform layer. In *Silent Consent, Persistent Risk: Android Permission Groups and Custom Permissions* [2], we measured both mechanisms at ecosystem scale, 19.3 million APKs, validated their exploitability on Android 16, showed that malware preferentially engages them, and built a transparency prototype that restores update-time consent visibility using only public APIs (§4).

Applications and the platform, however, are not the only sources of risk: users can be exploited directly, through the conversations their devices host. In pig-butcherer scams, a scammer cultivates a fabricated relationship over weeks of messaging before extracting money; the FBI attributes a substantial portion of \$4.57 billion in 2023 investment-fraud losses to such schemes [9]. No permission policy or platform hardening can protect a user who willingly sends money to someone they trust. My proposed work, *SIRENBERT: On-Device Detection of Pig-Butcherer Scams by Modeling Messages in Conversations*, defends this final layer: a privacy-preserving, on-device detector that tracks a conversation’s behavioral trajectory message by message and warns the user before the first money request (§5).

Thesis statement. *Mobile users can be protected from security and privacy harms by identifying and mitigating the distinct threats they face at each layer of the mobile ecosystem: measuring and disclosing predatory applications, restoring transparency to eroded platform consent mechanisms, and detecting conversational scams on-device before financial harm occurs.*

2 Background and State of the Art

2.1 Predatory Digital Lending

Loan apps promise fast, collateral-free microcredit to populations underserved by formal banking [15]. Many, however, obscure predatory terms and adopt digitized coercive debt-collection tactics enabled by data harvested at install time. Governments in affected countries have introduced registration and privacy constraints for digital lenders, and Google’s Financial Services Policy (FSP) prohibits personal-loan apps from requesting high-risk permissions such as `READ_CONTACTS` and `READ_SMS` [13]; yet abuse reports, and user suicides linked to loan-app harassment, persist. Prior academic work is primarily qualitative,

interviews and case studies documenting distress and perceived data misuse; before our work there was no large-scale technical measurement of whether regulator-approved apps actually comply with either national rules or platform policy.

2.2 The Android Permission Model and Its Legacy Mechanisms

Android’s permission system has been studied extensively for over-privilege and user comprehension [10, 11, 17]. Android 6.0’s runtime permissions were designed to restore informed consent, but two mechanisms inherited from Android 1.0 remain active in Android 16. *Permission groups* reduce prompt fatigue by auto-granting new permissions within an already-approved group during updates, with no dialog and no Settings indication. *Normal-level custom permissions*, the default when developers omit a protection level, are auto-granted at install to any requesting app regardless of developer identity. Prior work documented confused-deputy attacks and isolated exposures [16, 12], and Calciati et al. [4] measured group auto-grant on 2.9M app versions, but the mechanisms’ current prevalence, their association with malice, and their exploitability on modern Android remained open questions.

2.3 Detection of Long-Con Conversational Fraud

Pig-butcherer (*sha zhu pan*) is a long-con fraud whose variants (romance fraud, cryptocurrency mentorship, friendship-based exploitation) share one behavioral lifecycle: establish contact, build trust through sustained engagement, deploy deceptive positioning tactics, and issue a financial demand [6, 9]. The trust-building phase is designed to be indistinguishable from legitimate conversation, which defeats existing detection approaches. Keyword and rule-based detectors fire only once money language appears, after weeks of grooming, and misfire on ordinary money talk. Learned classifiers for the constituent sub-scams judge *completed* conversations, bag-of-words or fine-tuned encoders over full transcripts, verdicts that arrive after the harm is done. LLM judges are accurate but too costly and privacy-invasive to run on every message of every private conversation. No system detects pig-butcherer as a whole, and no labeled dataset follows these conversations message by message, the granularity at which a deployable detector must operate.

3 Completed Work I: The Cost of Convenience

The Cost of Convenience: Identifying, Analyzing, and Mitigating Predatory Loan Applications on Android [1], published at ACM ASIA CCS 2026, protects users at the application layer through measurement, disclosure, and policy recommendations.

Approach. We collected 434 loan apps from official regulator registries and app markets in Indonesia, Kenya, Nigeria, Pakistan, and the Philippines. Because compliance requirements exist as prose, we developed an LLM-assisted *policy-to-permission mapping* that translates regulatory and platform policy text into testable permission checks, and combined it with static analysis of app code and dynamic analysis of runtime behavior, including inspection of what data leaves the device and when.

Key findings. Non-compliance is pervasive among *approved* apps: 141 violate national regulatory policy and 147 violate Google’s FSP, with combined downloads exceeding 300 million. Dynamic analysis revealed 37 apps transmitting sensitive data (contacts, SMS, location, media) immediately at launch, before any signup or registration, eliminating even the possibility of informed consent. We further exposed systematic misalignment between national regulations and platform policy, gaps that allow an app to satisfy one authority while violating the other, and linked these gaps to concrete technical pathways for data misuse.

Impact. Following our coordinated disclosure, Google removed 93 flagged apps from Google Play. The methodology is directly usable by regulators and platforms as a proactive compliance-monitoring pipeline.

4 Completed Work II: Silent Consent, Persistent Risk

Studying how developers circumvent permission policies in §3 revealed that the platform itself provides circumvention paths by default. *Silent Consent, Persistent Risk: Android Permission Groups and Custom Permissions* [2] measures these paths at ecosystem scale and protects users by restoring the visibility the platform withholds.

Research questions. (RQ1) To what extent do permission groups enable silent capability expansion across updates? (RQ2) Is silent expansion an ecosystem-wide consent failure, or disproportionately an attribute of malware? (RQ3) How prevalent are normal-level custom permissions enabling cross-developer data access, and is exploitation confirmed on current Android? (RQ4) Can lightweight, interface-level interventions restore update-time visibility without OS modification?

Approach. We analyzed 19,324,760 APKs spanning 5,965,583 unique apps from AndroZoo [3], tracking permission evolution across versions; operationalized malice via VirusTotal detections under a principled threshold sensitivity sweep [18]; validated exploitability on-device on Android 16 with per-pair probe apps; and attributed the exposed surface to app-core code versus bundled third-party libraries.

Key findings. Among 2,244,575 multi-version apps, 381,026 (17%) silently gain permissions within already-granted groups, and the auto-grant fires across every dangerous group on Android 16 with no run-time dialog. Silent expansion is preferentially engaged by malware: odds ratio 1.35 ($p < 0.001$), rising to 2.06 in the most permission-heavy quartile, and significant at every tested detection threshold. We identified 307 cross-developer normal-custom-permission pairs re-delegating contacts, SMS, location, authentication credentials, identity, and medical records to unrelated apps without any prompt, confirmed active exploitability with instrumented probe apps, and attributed most of the exposed surface to bundled third-party libraries rather than app-core code.

Mitigation. A prototype built solely on public Android APIs restores update-time transparency: in a 96-day single-device deployment it surfaced 23 silent expansion events across 13 apps, including apps with over one billion installs, at roughly one notification every four days, showing consent visibility is achievable without OS modification.

5 Proposed Work: SIRENBERT

Applications and platform mechanisms are not the only vectors of harm: users themselves engage with scammers through the conversations their devices host, and this conversation layer is the least protected today. My proposed work is *SIRENBERT: On-Device Detection of Pig-Butchering Scams by Modeling Messages in Conversations*, for which I have strong preliminary results.

5.1 Preliminary Results

Lifecycle formalization. We formalize the pig-butchering lifecycle, previously described only qualitatively, as a five-state machine over per-message *behavioral triggers* (e.g., credential positioning, platform migration, manufactured crisis, financial demand), turning a descriptive account into a supervision target a model can be trained on and a state a detector can track.

Dataset. We constructed, to our knowledge, the first message-level labeled dataset for pig-butchering: 12,296 conversations spanning real victim transcripts, scammer–scambaiter logs, and benign dialogue, labeled message by message by an LLM annotation framework restricted to the same message prefix a deployed detector would observe, with no oracle access to how the conversation ends.

Architecture. Detection decomposes into two stages: a context-aware encoder (Stage 1), built on a compact BERT-family model [8, 14], reads each incoming message with a window of preceding messages and emits behavioral-trigger probabilities; a lightweight unidirectional GRU [5] (Stage 2) reasons over the

accumulated trigger sequence and re-evaluates conversation-level risk after every message, with an auxiliary early *setup warning*. Only trigger vectors are buffered; raw message text is never stored for model inference or transmitted off device.

Results. SIRENBERT attains 0.99 held-out conversation SCAM-F1, outperforming keyword, per-message, whole-conversation, and LLM-judge baselines, and, critically for a warning system, alerts a median of eleven messages *before* the first money request on 76% of scam conversations. The trajectory model’s largest measured effect is false-positive control: demand-like language is weighed against the setup behavior that preceded it, so ordinary money talk does not trigger alarms. The setup-warning channel also surfaces the 37 of 83 real victim transcripts in our data that end before any explicit demand, conversations invisible to any demand-triggered detector. The full pipeline runs on-device in an Android messaging client, processing each message in under one second.

5.2 Remaining Research Tasks

RT1 — Adversarial robustness. A deployed detector will be attacked. I will systematically evaluate and harden SIRENBERT against adaptive adversaries: distractor padding (preliminary ablations exist), paraphrase and persona shifts, LLM-assisted scammers that rewrite scripted stages, and slow-play strategies that stretch the lifecycle. Outcomes: an adversarial evaluation suite and hardened model variants with quantified robustness bounds.

RT2 — Cross-platform and demand-free coverage. Platform migration is a scripted scam step, so exploitation often completes in a different app than where grooming occurred. I will extend the on-device design to maintain trajectory state across messaging applications under explicit user consent, and expand the dataset’s demand-free and multilingual coverage, the hard cases where benchmark performance does not yet reflect deployment difficulty.

RT3 — User-facing warnings. A warning eleven messages early is only useful if the user believes it. I will design and evaluate warning interfaces (timing, framing, escalation) through an IRB-approved user study measuring comprehension, trust, and behavioral response, particularly for users already emotionally invested in the conversation, the population prior work shows is hardest to dissuade.

5.3 Anticipated Contributions

This dissertation will contribute, at the application layer, the first cross-country compliance-measurement methodology for financial apps, with demonstrated real-world impact (93 removals, 300M+ installs); at the platform layer, the largest longitudinal measurement of consent erosion in Android permissions, evidence that malware preferentially exploits it, and a practical transparency countermeasure requiring no OS modification; and at the conversation layer, the first lifecycle formalization, message-level dataset, and on-device early-warning detector for pig-butcherings scams, hardened against adaptive adversaries and validated with real users. Collectively, the work advances mobile security from post-hoc, transcript-level, single-point responses toward proactive protection of users at every layer where exploitation reaches them.

6 Research Plan and Timeline

7 Summary

Mobile users are exploited through the apps they install, the platform mechanisms meant to govern those apps, and the conversations they trust. My completed work has protected users at the first two layers, removing predatory apps from the ecosystem and restoring visibility into silent consent erosion, each with

Period	Milestones
Fall 2026	Prospectus defense. RT1: adversarial evaluation suite and hardening; submit SIRENBERT to a top-tier security venue.
Spring 2027	RT2: cross-platform trajectory tracking; dataset expansion (demand-free, multilingual). RT3 study design and IRB approval.
Summer 2027	RT3: conduct and analyze user study of warning interfaces.
Fall 2027	Complete remaining evaluations; submit resulting paper; begin dissertation writing.
Spring 2028	Complete dissertation; defense.

Table 1: Anticipated timetable for completion.

demonstrated real-world impact. The proposed work completes the third: an on-device, privacy-preserving early-warning system that reaches users at the moment of manipulation, before financial harm occurs.

References

- [1] Olawale Amos Akanji, Manuel Egele, and Gianluca Stringhini. The cost of convenience: Identifying, analyzing, and mitigating predatory loan applications on android. In *Proceedings of the ACM Asia Conference on Computer and Communications Security (ASIA CCS)*. ACM, 2026.
- [2] Olawale Amos Akanji, Manuel Egele, and Gianluca Stringhini. Silent consent, persistent risk: Android permission groups and custom permissions. *Under submission*, 2026.
- [3] Kevin Allix, Tegawendé F. Bissyandé, Jacques Klein, and Yves Le Traon. Androzoo: Collecting millions of android apps for the research community. In *Proceedings of the International Conference on Mining Software Repositories (MSR)*, 2016.
- [4] Paolo Calciati, Konstantin Kuznetsov, Alessandra Gorla, and Andreas Zeller. Automatically granted permissions in android apps: An empirical study on their prevalence and on the potential threats for privacy. *Proceedings of the International Conference on Mining Software Repositories (MSR)*, 2020.
- [5] Kyunghyun Cho, Bart van Merriënboer, Caglar Gulcehre, Dzmitry Bahdanau, Fethi Bougares, Holger Schwenk, and Yoshua Bengio. Learning phrase representations using RNN encoder–decoder for statistical machine translation. In *Proceedings of EMNLP*, 2014.
- [6] Cassandra Cross. Romance baiting, cryptorom and ‘pig butchering’: An evolutionary step in romance fraud. *Current Issues in Criminal Justice*, 36(3):334–346, 2024.
- [7] Asli Demirgüç-Kunt, Leora Klapper, Dorothe Singer, and Saniya Ansar. The global finindex database 2021: Financial inclusion, digital payments, and resilience in the age of covid-19. Technical report, World Bank, 2022.
- [8] Jacob Devlin, Ming-Wei Chang, Kenton Lee, and Kristina Toutanova. BERT: Pre-training of deep bidirectional transformers for language understanding. In *Proceedings of NAACL-HLT*, 2019.
- [9] Federal Bureau of Investigation. Internet crime report 2023. Technical report, FBI Internet Crime Complaint Center (IC3), 2024.
- [10] Adrienne Porter Felt, Erika Chin, Steve Hanna, Dawn Song, and David Wagner. Android permissions demystified. In *Proceedings of the ACM Conference on Computer and Communications Security (CCS)*, 2011.

- [11] Adrienne Porter Felt, Elizabeth Ha, Serge Egelman, Ariel Haney, Erika Chin, and David Wagner. Android permissions: User attention, comprehension, and behavior. In *Proceedings of the Symposium on Usable Privacy and Security (SOUPS)*, 2012.
- [12] Julien Gamba, Mohammed Rashed, Abbas Razaghpanah, Juan Tapiador, and Narseo Vallina-Rodriguez. An analysis of pre-installed android software. In *Proceedings of the IEEE Symposium on Security and Privacy (S&P)*, 2020.
- [13] Google. Google play financial services policy. <https://support.google.com/googleplay/android-developer/answer/9876821>. Accessed 2026.
- [14] Victor Sanh, Lysandre Debut, Julien Chaumond, and Thomas Wolf. DistilBERT, a distilled version of BERT: Smaller, faster, cheaper and lighter. *arXiv preprint arXiv:1910.01108*, 2019.
- [15] Tavneet Suri and William Jack. The long-run poverty and gender impacts of mobile money. *Science*, 354(6317):1288–1292, 2016.
- [16] Güliz Seray Tuncay, Soteris Demetriou, Karan Ganju, and Carl A. Gunter. Resolving the predicament of android custom permissions. In *Proceedings of the Network and Distributed System Security Symposium (NDSS)*, 2018.
- [17] Primal Wijesekera, Arjun Baokar, Ashkan Hosseini, Serge Egelman, David Wagner, and Konstantin Beznosov. Android permissions remystified: A field study on contextual integrity. In *Proceedings of the USENIX Security Symposium*, 2015.
- [18] Shuofei Zhu, Jianjun Shi, Limin Yang, Boqin Qin, Ziyi Zhang, Linhai Song, and Gang Wang. Measuring and modeling the label dynamics of online anti-malware engines. In *Proceedings of the USENIX Security Symposium*, 2020.